

Tear Down this Zywall!

Breaking Open Zyxel Encrypted Firmware



AGENDA

- Introduction
- How it Started
- The Firmware
- The Hardware
- The Software
- How it's Going
- Future Work
- Questions

• INTRODUCTION

Who's this moron?

whoami

- LAGORIO\Jay (jay@lagor.io)
- B.S. Computer Science, UMBC (2008)
- M. Eng. Electrical Engineering, NPS (2015)
- CISSP, various SANS certifications over the years
- Windows Developer, Security Consultant, Licensed Private Investigator
- Talks at Hackfest.ca 10, DC27 Biohacking Village, Kernelcon 2
- Unrepentant nerd



• **HOW IT STARTED**

There's backdoors in them thar hills

IT WAS DECEMBER 2020

SN
Fri 12/18/2020 3:00 AM
Security News <security_news@zyxel.com.tw>
Zyxel New Release to Elevate your Network!

To Jay Lagorio

 If there are problems with how this message is displayed, click here to view it in a web browser.

Utility Belt Yesware + Get more add-

b



Thank you for choosing [ZyWALL Series](#). Zyxel Networks maintenance release will be available for major models as part of a security improvement process. This ZLD4.60 patch 1 release enhances all-round functions of ZyWALL products including:

Item	Description	CVE
Enhancement	Undocumented user account vulnerability fix.	CVE-2020-29583
Enhancement	Enhanced HA Pro reliability	-

• **IT WAS DECEMBER 2020** •



• IT WAS DECEMBER 2020 •

Undocumented user account in Zyxel products (CVE-2020-29583)



Niels Teusink / Cybersecurity Specialist

TL;DR: If you have a Zyxel USG, ATP, VPN, ZyWALL or USG FLEX you should update to the latest firmware version today. You can find the full list of affected devices [here](#) and the Zyxel advisory [here](#).

Zyxel is a popular brand for firewalls that are marketed towards small and medium businesses. Their Unified Security Gateway (USG) product line is often used as a firewall or VPN gateway. As a lot of us are working from home, VPN-capable devices have been quite selling well lately.

When doing some research (rooting) on my Zyxel USG40, I was surprised to find a user account 'zyfwp' with a password hash in the latest firmware version (4.60 patch 0). The plaintext password was visible in one of the binaries on the system. I was even more surprised that this account seemed to work on both the SSH and web interface.

• **IT WAS DECEMBER 2020** •

100,000 – 300,000 Potential Devices

• **THE FIRMWARE**

We'll just binwalk it and call it a day

THE FIRMWARE

HxD - [C:\Users\Jay\Downloads\460AALA0C0.bin]

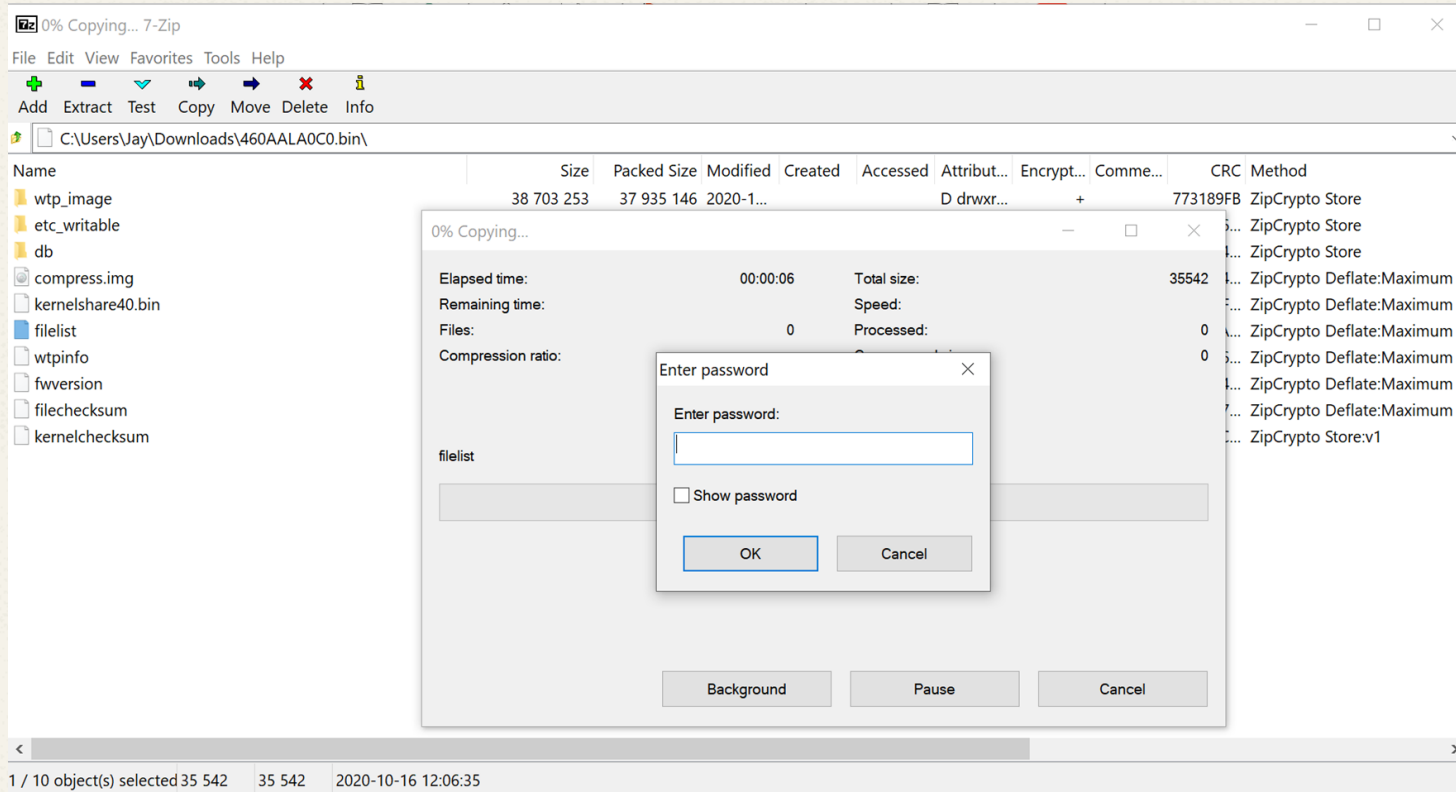
File Edit Search View Analysis Tools Window Help

16 Windows (ANSI) hex

460AALA0C0.bin

Offset (h)	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F	Decoded text
00000000	50	4B	03	04	14	00	0B	00	08	00	1A	BB	50	57	A4		PK.....»PQW»
00000010	6C	95	17	9F	7D	05	00	30	8F	05	0C	00	15	00	00		I*.I}..0.....co
00000020	6D	70	72	65	73	73	2E	69	6D	67	55	54	00	00	00		mpress.imgUT...C
00000030	BB	89	5F	02	C5	89	5F	55	78	04	00	00	00	00	00		»%. .Å%_Ux.....+
00000040	7E	68	EB	D6	EE	ED	27	76	B8	A7	00	00	00	00	00		~hëÖiï'v, \$PkZ.²Å
00000050	F7	B4	5E	5A	DE	19	E6	80	6A	3C	E0	00	00	00	00		÷^ZP.æEj<iE;è°Å
00000060	9D	12	D6	BC	9E	9F	95	1C	32	2E	FE	00	00	00	00		..Ö4zÿ*.2.p..é%<
00000070	EC	56	54	78	D0	F8	34	E3	01	DF	9D	5D	60	54	A5	11	ivITxÐø4ã.B.=`T¥.
00000080	22	0E	C9	08	AD	28	E4	05	54	2B	86	03	D2	4B	02	0C	".É... (ä.T++.ÒK..
00000090	52	AC	D8	FC	A2	58	60	B3	4A	6E	5E	97	E7	22	70	77	R-ØüçX`³Jn^~ç"pw
000000A0	AG	EA	E9	EE	24	B3	36	16	02	73	E0	7B	8E	3B	5C	D7	;ééi\$³6..sà{Ž;\×
000000B0	CF	C2	F1	A7	92	80	0F	79	2A	4A	52	0A	A4	B5	16	74	İÂñ\$'€..y*JR.µµ.t
000000C0	4B	13	83	6F	02	31	29	42	8D	C4	9B	DF	4E	5D	CA	D1	K.fo.1)B.Ä>BN]ÊÑ
000000D0	5F	6F	56	6B	98	34	D6	49	74	58	4A	68	92	FC	ED	C8	_oVk~4ÖItXJh'úiÈ
000000E0	01	90	F0	5B	AA	85	14	C8	A6	A4	5A	59	1B	E7	12	77	..ð[²....È;µZY.ç.w

THE FIRMWARE



THE FIRMWARE

- ✓ We know it's a Zip file
- ✓ The file is password protected
- ✓ We can see what files are inside
- ✓ Some files are available online
- ✓ The update process doesn't require a password
- ✓ 7zip says there's a trailer

Properties	
Size	140 036 412
Packed Size	136 477 581
Folders	16
Files	470
CRC	E6224753

Path	\\wsl\$\\Ubuntu-20.04\\home\\ubuntu\\462AAKY0C0.bin
Type	zip
Warnings	There are some data after the end of the payload data
Physical Size	136 575 209
Tail Size	126 860



THE FIRMWARE

- Default passwords didn't work
- Zip Plain-Text Attack
 - Attack from 1994
 - Given a ZipCrypto archive and one file from inside the archive
 - Derive the keystream for the rest of the archive
 - Now you have the decrypted archive

THE FIRMWARE

INSERT DIRLIST OF FTP.ZYXEL.COM

THE FIRMWARE

Security Announcement - Change FTP Service to HTTPS Download Service



Tobias Hermanns

6 days ago · Updated

Follow



Print



PDF



Email

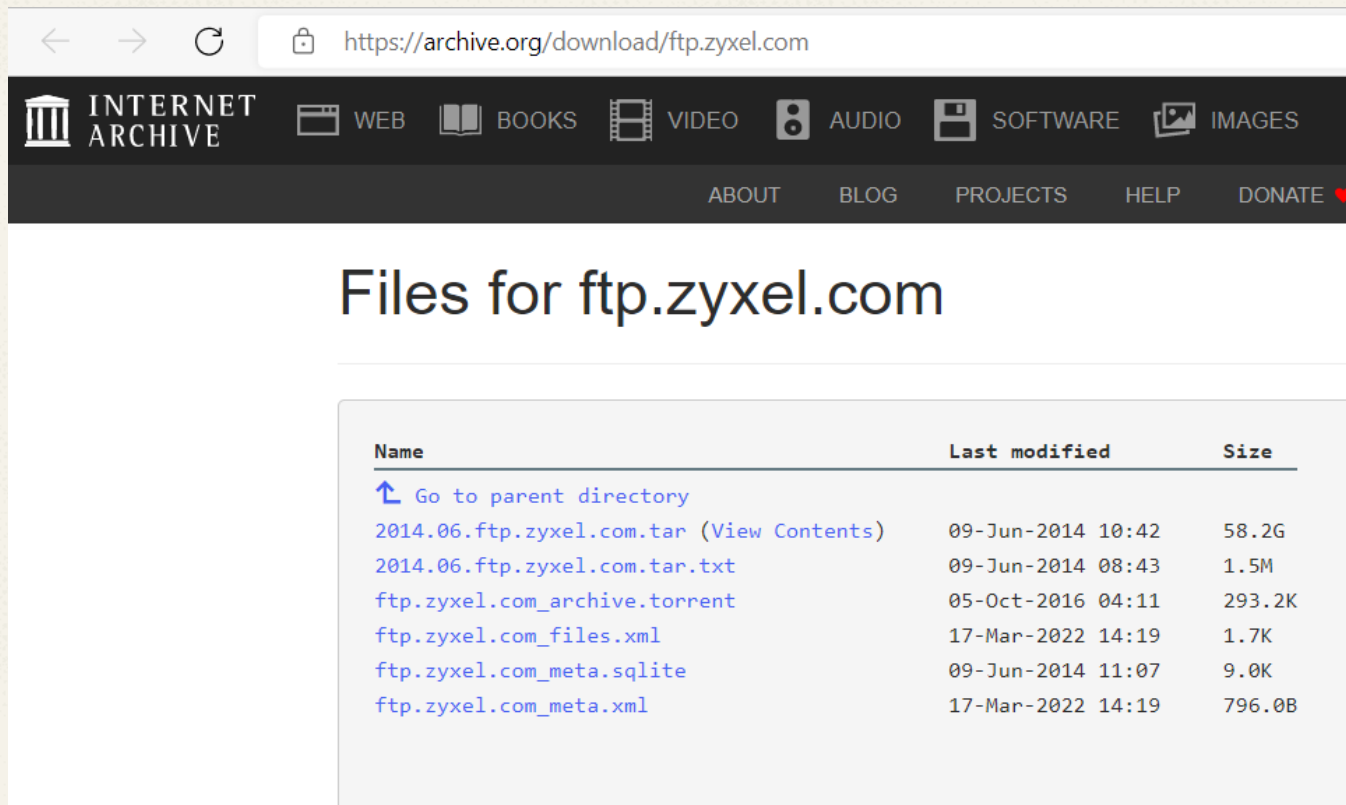
Due to security concerns and the modern browsers not supporting FTP (for example Chrome or Firefox) anymore, we decided to change our FTP server to a download library based on HTTPS.

This change will take effect by March 2021.

We will stop providing FTP services from March 2021 due to security concern. Users will be unable to download materials (including firmware, datasheet... etc.) from <ftp://ftp> and <ftp://ftp2>.

We will replace <ftp://ftp.zyxel.com/> and <ftp://ftp2.zyxel.com/> with our [Zyxel Download Library](#), so users will still be able to download materials via HTTPS.

THE FIRMWARE



The screenshot shows a web browser window with the address bar displaying `https://archive.org/download/ftp.zyxel.com`. The browser's navigation bar includes the Internet Archive logo and icons for various media types: WEB, BOOKS, VIDEO, AUDIO, SOFTWARE, and IMAGES. Below this, a dark navigation bar contains links for ABOUT, BLOG, PROJECTS, HELP, and DONATE (with a red heart icon). The main content area is titled "Files for ftp.zyxel.com" and features a table of files.

Name	Last modified	Size
Go to parent directory		
2014.06.ftp.zyxel.com.tar (View Contents)	09-Jun-2014 10:42	58.2G
2014.06.ftp.zyxel.com.tar.txt	09-Jun-2014 08:43	1.5M
ftp.zyxel.com_archive.torrent	05-Oct-2016 04:11	293.2K
ftp.zyxel.com_files.xml	17-Mar-2022 14:19	1.7K
ftp.zyxel.com_meta.sqlite	09-Jun-2014 11:07	9.0K
ftp.zyxel.com_meta.xml	17-Mar-2022 14:19	796.0B

THE FIRMWARE

- Used `github:kimci86/bkcrack` to run the attack
- This didn't work
- Maybe I don't have the right files?
- One more strategy to try

THE FIRMWARE

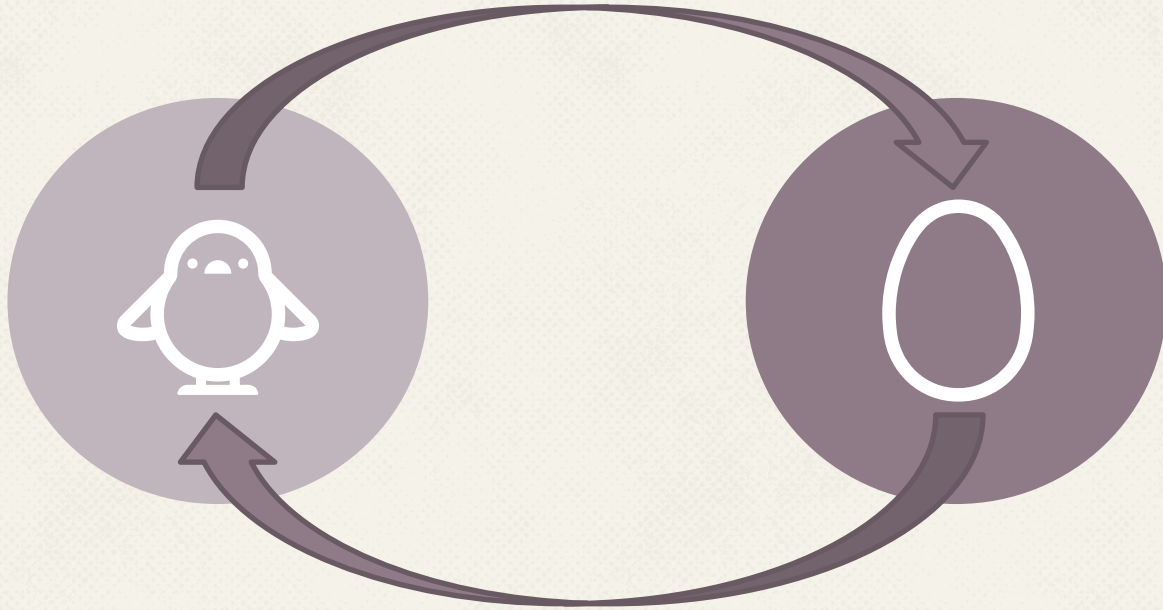
- Password Cracking
 - Both LostPassword and JohnTheRipper
 - Touchy about that trailer, had to strip it
 - Gave each a couple days while brainstorming
 - Total failure. Cool.

THE FIRMWARE

Are ya winning son?



THE FIRMWARE



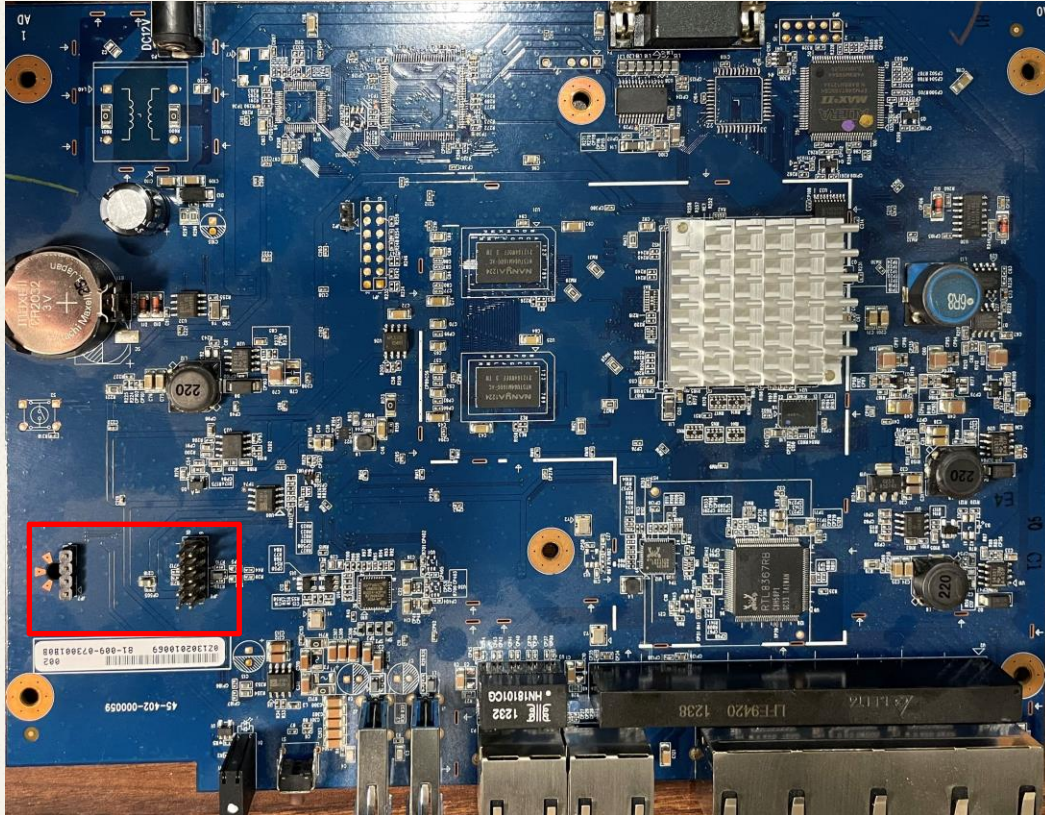
• THE HARDWARE

Crackin' the case

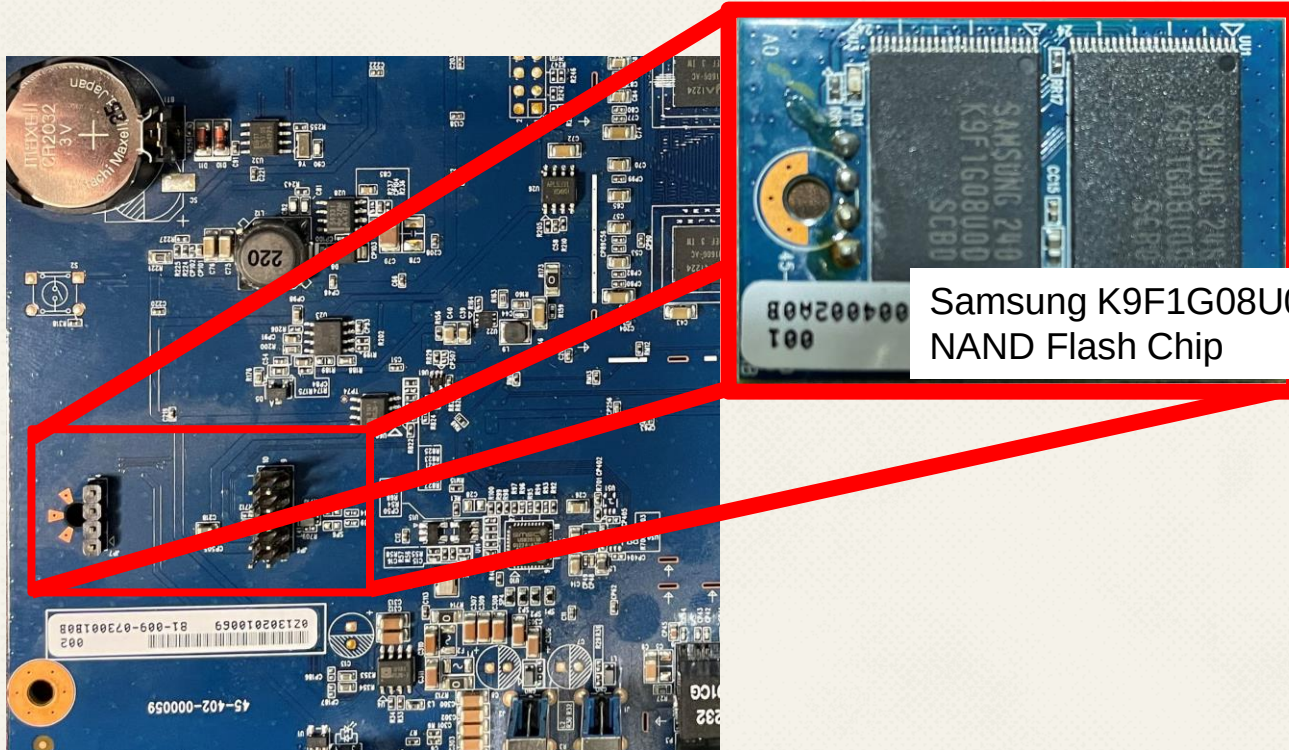
THE HARDWARE



THE HARDWARE



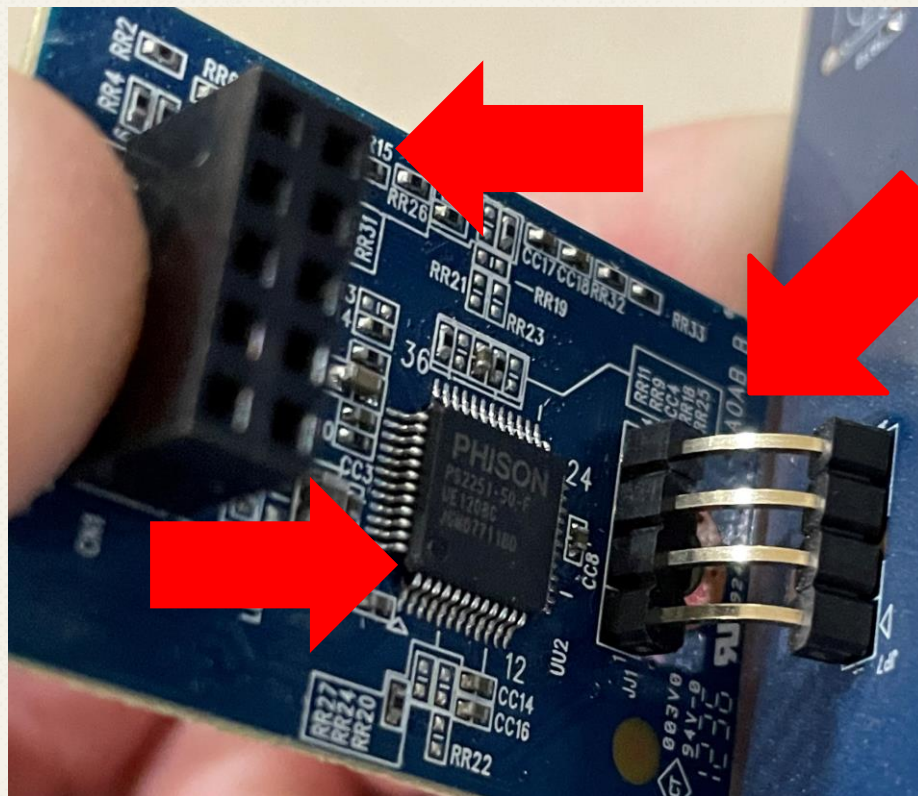
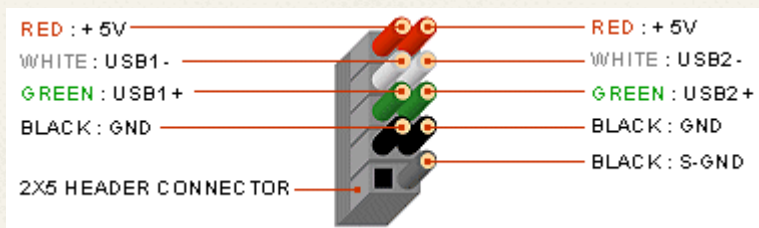
THE HARDWARE



Samsung K9F1G08U0
NAND Flash Chip

THE HARDWARE

- 10 pin connector
- PHISON PS2251-50-F
- ???



THE HARDWARE



THE HARDWARE

- The drive mounts – we have a disk!
- Use Win32DiskImager to image the entire drive
- Throw the image in BinWalk
- And out pops the firmware in plain-text!
- ...but only the firmware on THIS device.

THE HARDWARE

But decrypting arbitrary firmware files?

• THE SOFTWARE

Decompilers are free now!

THE SOFTWARE

The screenshot displays the ZYXEL USG60 web management interface. The left sidebar shows the 'MAINTENANCE' menu with options like File Manager, Diagnostics, Packet Flow Explore, and Shutdown/Reboot. The main content area is divided into tabs: Configuration File, Firmware Management (selected), and Shell Script. Under the 'Firmware Management' tab, the 'Firmware Status' section shows a table of installed firmware versions. Below this, the 'Cloud Firmware Information' section provides a note about registering at portal.myzyxel.com and details about the latest firmware version (4.65(AAKY.0)) and its release date (2021-07-01). The 'Auto Update' section is also visible. A 'Local Firmware' dialog box is open in the foreground, titled 'Local Firmware', with a sub-section 'Upload File'. It contains instructions: 'To upload firmware, browse to the location of the file (*.bin) and then click Upload.' Below this, there is a 'File Path:' label, a text input field, and 'Browse...' and 'Upload' buttons. A 'Cancel' button is located at the bottom right of the dialog box.

ZYXEL USG60

MAINTENANCE

- File Manager
- Diagnostics
- Packet Flow Explore
- Shutdown/Reboot

Firmware Management

Firmware Status

Reboot

#	Status	Model	Version	Released Date
1	Running	USG60	V4.64(AAKY.0)	2021-06-25 23:47
2	Standby	USG60	V4.63(AAKY.0)	2021-05-11 13:09

Page 1 of 1 Show 50 items

Cloud Firmware Information

Note:

- Register at portal.myzyxel.com to power up with auto firmware notification.
- Schedule Reboot and Auto Firmware Update. If Auto Firmware Update is enabled, then you can schedule the firmware update.

Latest Version: 4.65(AAKY.0)
Release Date: 2021-07-01
Release Note: [Release Note](#)

☐ Auto Update

☐ Daily 20
☐ Weekly Sunday
☒ Auto Reboot

Local Firmware

Upload File

To upload firmware, browse to the location of the file (*.bin) and then click Upload.

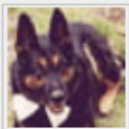
File Path:

Firmware Upgrade Service Status

THE SOFTWARE

- Device runs an Apache web server
- Submits to `firmware_upload-cgi` in `cgi-bin`
- Contains string `/util/zld_fsextract`
 - File System Extract?
- Let's Google it

THE SOFTWARE



Brano

I hate Vogons

MVM

join:2002-06-25

Burlington, ON

(Software) OPNsense

Ubiquiti UniFi UAP-AC-

PRO

Ubiquiti NanoBeam M5 16

Seems to be

quote:

3.00(AQU.0) / 2012-02-17 16:50:38

You can always compare the .bin files once it shows on US ftp servers.

I would not worry that this is some kind of fake, **USG firmwares are zipped with very strong password.** The **zld_fsextract** update command then verifies the zip and unzips it before applying the update. For somebody to fake the firmware they must know how to generate the proper password (each update has different password) ... just watch console output during update if you're curious.



+1

· [actions](#)

2012-Mar-2

9:10 pm ·

[reply](#)

THE SOFTWARE

- The binary's from a previous model though...
 - Same processor architecture
 - Firmware formats appear the same
 - If it ain't broke, why fix it?

Spoiler: the newer models have the same binary so we made a smart bet

THE SOFTWARE

- Run file
 - ELF 32-bit MSB executable, MIPS, N32 MIPS64 rel2 version 1 (SYSV), statically linked, stripped
- Run strings
 - usage: %s <input zip file> {-t | <unzip path> {-s <SET_EXTRACTION_COMMAND> | [-f file1 [-f file2 ...]] [-d dir1 [-d dir2 ...]] [-i]]} [-D destDir]}
 - 7za

THE SOFTWARE



THE SOFTWARE

```
10002fc4 - LAB_10002fc4
LAB_10002fc4
...2fc4 lw    a1,-0x7fd0(gp)=>PTR_LAB_10...
...2fc8 lw    t9,-0x7e80(gp)=>->FUN_1000...
...2fcc daddu a0,s3,zero
...2fd0 jalr  t9=>FUN_1000a0e0
...2fd4 _ad... a1=>s_7za_10011530,a1,0x15...
...2fd8 bne   v0,zero,LAB_10002eec
...2fdc _nop
```

```
10002e78
...2e78 lw    v0,-0x7fe8(gp)=>PTR_10114b...
...2e7c lw    v1,-0x7fe8(gp)=>PTR_10114b...
...2e80 sw    s6,local_5000(sp)
...2e84 lw    a0,offset DAT_10114fcc(v0)
...2e88 lw    v0,-0x7fd0(gp)=>PTR_LAB_10...
...2e8c lw    a1,offset DAT_10114fc4(v1)
...2e90 lw    v1,-0x7fd0(gp)=>PTR_LAB_10...
...2e94 addiu v0,v0,0x1518
...2e98 sw    v0=>DAT_10011518,local_500...
...2e9c lw    v0,-0x7fd0(gp)=>PTR_LAB_10...
...2ea0 addiu v1,v1,0x1518
...2ea4 sw    v1=>DAT_10011518,local_500...
...2ea8 addiu v0,v0,0x1518
...2eac sw    v0=>s_-P_10011520,local_50...
...2eb0 sw    a0,local_4ffc(sp)
...2eb4 beq   a1,zero,LAB_10002ed0
...2eb8 _li   s4,0x6
```

THE SOFTWARE

- Qemu Usermode Emulation for MIPS to run it
 - `sudo cp ld-2.3.3.so /lib/`
 - `sudo ln /lib/ld-2.3.3.so /lib/ld.so.1`
- Run it with `strace` to find calls out to `7za`
 - `qemu-mipsn32 -strace zld_fsextract 460AAKY1C0.bin -i &2>1 > out.txt`

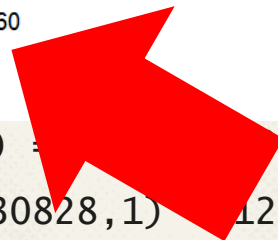
THE SOFTWARE

- 23402 open("460AAKY1C0.bin",O_RDONLY)
- 23402 ioctl(3,21517,1082130192,0,
(Inappropriate ioctl for device)
- 23402 brk(0x10136000) = 0x10136000
- 23402 lseek(3,-12,2,269700176,1082130192)
- 23402 Linux(3,1082130448,4,269700176,1082130192)
- 23402 Linux(3,1082130452,4,269700176,1082130192)
- 23402 brk(0x10155000) = 0x10155000
- 23402 lseek(3,-126860,2,269704280,1082130828,1) = 1082130828
- 23402 lseek(3,126848,2,269700112,1082130828,1) = 1082130828

Properties

Size	140 036 412
Packed Size	136 477 581
Folders	16
Files	470
CRC	E6224753

Path	\\wsl\$\Ubuntu-20.04\home\ubuntu\462AAKY0C0.bin
Type	zip
Warnings	There are some data after the end of the payload data
Physical Size	136 575 209
Tail Size	126 860



THE SOFTWARE

- `qemu-mipsn32 -strace zld_fsextract 460AAKY1C0.bin -i &2>1 > out.txt`
- `23408 execve("-i",{ "-i", "-o", "-q", "-P",
"iRqoEoQpA", "0lw9ksF4XgFh0iyehh6YVMMxCYa0G0ohnKsXC8em", "yL8",
"460AAKY1C0.bin", "db/etc/", NULL}) =
-1 errno=2 (No such file or directory)`

THE SOFTWARE

```
// printarg4.c

#include <stdio.h>
int main(int argc, char* argv[])
{
    printf("%s\n", argv[4]);
    return 0;
}
```


THE SOFTWARE

```
ubuntu@DESKTOP-TCPR2F3: ~  
ubuntu@DESKTOP-TCPR2F3:~$ qemu-mipsn32 zld_fsextract 460AALA0C0.bin printarg4  
SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO  
.SBHsDFVHwZrVnhN7mLAJYyfDWlQdsJiKW/ClGj2Civj5c6FOTRk1PPGxAja22IO
```

• **HOW IT'S GOING**

We fucked around, now let's find out!

THE BUG

- It turns out my backup of the firmware got corrupted.
 - Are you testing your backup strategy?
 - No? Then do you actually have one?
- This version of the firmware is completely gone.
- What to do?
- I extracted it like this, and since we already know the IOCs we can grep for them.

THE BUG

```
ubuntu@DESKTOP-TCPR2F3: ~/460AALA0C0/_compress.img.extracted/squashfs-root
ubuntu@DESKTOP-TCPR2F3:~/460AALA0C0/_compress.img.extracted/squashfs-root$ grep -r zyfw *
Binary file bin/zyshd matches
etc/zyxel/sys/shadow.basic:zyfw:$5$cU1FaqIM$BQaZ68B0$LnPwuAEpbclMsWzbG2v/r37AcSJWIW7pA2ZIkDiWnZ6dTBSMGK/5m7h0s5gPsQs8o/1aRcsc4yYEWqoKsJ3EPYKuxd+puMJY1/qQ2vKARhE1kPTfzox0rpyfm9dK5WDPa0aNilmqjYrhbcwCkpZTPttVBA5WhykxCAVPioMpgMZLsq8GW0Jyn4VLAipyYEa5z3xCdRgCzPZ9vBM5bLIStEE4fxRAZnk0hHNRr+MQP5FKHgsxRoABw+rdw0wA2TRfQvi3dfWKS1NZIMfkrTxofi0hCDAHQw/ed8G9IeN+TTruRggrGnK0WIvDy67o46uikMJ7ugpB0+OzUi+QEBMNEdS4hs/xpG5BHDYq/O6Pqzo$:18317:0:99999:::
etc/zyxel/sys/passwd.basic:zyfw:x:14:50:Local User&admin&120&120&1440&1440&1&0:/etc/zyxel/ftp:/bin/zysh
Binary file lib/security/pam_uam.so matches
Binary file lib32/security/pam_uam.so matches
Binary file usr/local/bin/capwap/capwap_srv matches
ubuntu@DESKTOP-TCPR2F3:~/460AALA0C0/_compress.img.extracted/squashfs-root$
```

```
zyfw:$5$cU1FaqIM$BQaZ68B0$LnPwuAEpbclMsWzbG2v/r37AcSJWIW7pA2ZIkDiWnZ6dTBSMGK/5m7h0s5gPsQs8o/1aRcsc4yYEWqoKsJ3EPYKuxd+puMJY1/qQ2vKARhE1kPTfzox0rpyfm9dK5WDPa0aNilmqjYrhbcwCkpZTPttVBA5WhykxCAVPioMpgMZLsq8GW0Jyn4VLAipyYEa5z3xCdRgCzPZ9vBM5bLIStEE4fxRAZnk0hHNRr+MQP5FKHgsxRoABw+rdw0wA2TRfQvi3dfWKS1NZIMfkrTxofi0hCDAHQw/ed8G9IeN+TTruRggrGnK0WIvDy67o46uikMJ7ugpB0+OzUi+QEBMNEdS4hs/xpG5BHDYq/O6Pqzo$:18317:0:99999:::
```

THE BUG

Decompile: initACMutIMI - (capwap_srv)

```
1
2 void initACMutIMI(fwInfo_s *fwInfo)
3
4 {
5     char *ftpPath;
6
7     fwInfo->fwUpgradeMethod = 1;
8     fwInfo->ftpPort = 0x15;
9     fwInfo->ftpID[0] = 'z';
10    fwInfo->ftpID[1] = 'y';
11    fwInfo->ftpID[2] = 'f';
12    fwInfo->ftpID[3] = 'w';
13    fwInfo->ftpID[4] = 'p';
14    fwInfo->ftpID[5] = '\0';
15    fwInfo->ftpID[5] = '\0';
16    *(undefined8 *)fwInfo->ftpPwd = 0x50724f7721614e5f;
17    fwInfo->ftpPwd[8] = 'f';
18    fwInfo->ftpPwd[9] = 'X';
19    fwInfo->ftpPwd[10] = 'p';
20    fwInfo->ftpPwd[0xb] = '\0';
21    fwInfo->ftpPwd[0x7f] = '\0';
22    snprintf(fwInfo->ftpPath, 0x40, &UNK_10098018, &UNK_10097ff8);
23    fwInfo->ftpPath[0x3f] = '\0';
24    fwInfo->failAction = '\0';
25    return;
26 }
27
```

Offset(h)	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F	Decoded text
00000000	50	72	4F	77	21	61	4E	5F	66	58	70						PrOw!aN_fXp

• **FUTURE WORK**

Stuff I'm never going to have time for

THE FUTURE

- Make a Python script
 - The deobfuscation function is at 0x10009F00 and is called from what calls 7za at 0x10002DE0

THE FUTURE

- It turns out all this was way easier than I made it
- Firmware updates include the firmware, some release notes, a .ri file for recovery
- It's unencrypted, you can binwalk it directly, and it contains `zld_fsextract`
- Thanks to HN Security for pointing out what should have been obvious

THE FUTURE

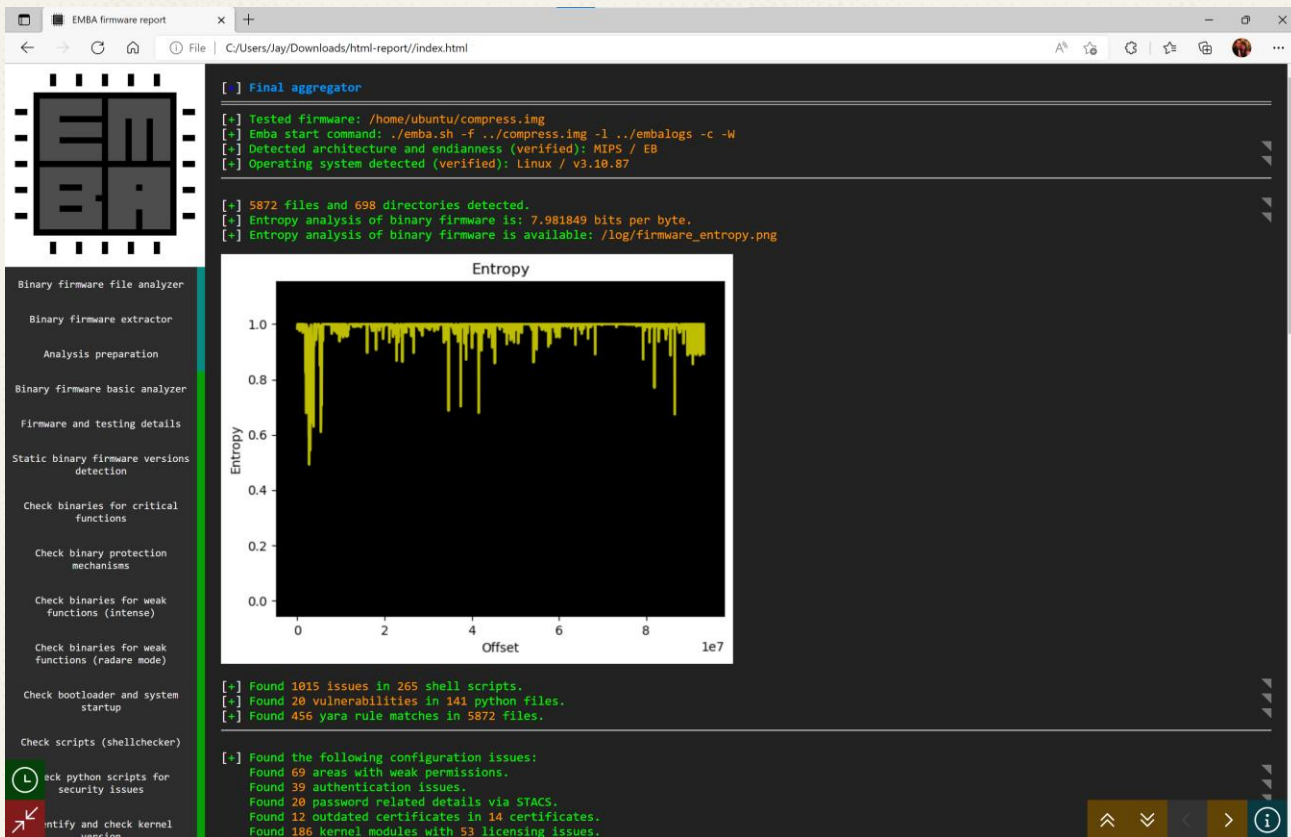
DECIMAL	HEXADECIMAL	DESCRIPTION
0	0x0	ASCII cpio archive (SVR4 with no CRC), file name: ".", file name length: "0x00000002", file si
112	0x70	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit", file name length: "0x00000007", fi
232	0xE8	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/zyinit", file name length: "0x0000000C", fi
266064	0x40F50	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/etc_inittab", file name length: "0x0000000A", fi
269196	0x41B8C	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/e2fsck", file name length: "0x0000000A", fi
709204	0xAD254	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/zld_mrd.ko", file name length: "0x0000000A", fi
715356	0xAEA5C	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/rw.zip", file name length: "0x0000000A", fi
2879904	0x2BF1A0	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/mke2fs", file name length: "0x0000000A", fi
3151288	0x3015B8	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/switchdev.ko", file name length: "0x0000000A", fi
3196236	0x30C54C	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/zld_fsextract", file name length: "0x0000000A", fi
3290728	0x323668	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/cn60xx.ko", file name length: "0x0000000A", fi
3312388	0x328B04	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/switchdev", file name length: "0x0000000A", fi
3391488	0x33C000	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/rw.zip", file name length: "0x0000000A", fi
3396772	0x33D4A4	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/zyinit_gpl", file name length: "0x0000000A", fi
3745356	0x39264C	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/fwversion", file name length: "0x0000000A", fi
3745816	0x392818	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/switchdev_char.ko", file name length: "0x0000000A", fi
3768480	0x3980A0	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/unzip", file name length: "0x0000000A", fi
3946956	0x3C39CC	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/lkm.lst", file name length: "0x0000000A", fi
3947164	0x3C3A9C	ASCII cpio archive (SVR4 with no CRC), file name: "zyinit/platform_support.ko", file name length: "0x0000000A", fi
3966960	0x3C87F0	ASCII cpio archive (SVR4 with no CRC), file name: "init", file name length: "0x00000005", file
3967092	0x3C8874	ASCII cpio archive (SVR4 with no CRC), file name: "TRAILER!!!", file name length: "0x0000000B", fi



THE FUTURE

- Make a Python script
 - The deobfuscation function is at 0x10009F00 and is called from what calls 7za at 0x10002DE0
- Run the decrypted firmware through EMBA
 - `compress.img` is your friend

THE FUTURE



THE FUTURE

[+] STRCPY - top 10 results:

93	:	libreadline.so.	:	common linux file: yes		No RELRO		No Canary		NX disabled		No Symbols		No Networking
73	:	libnetsnmpmibs.	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
51	:	libkrb5.so.3	:	common linux file: yes		No RELRO		No Canary		NX disabled		Symbols		Networking
41	:	pam_uam.so	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
38	:	pro	:	common linux file: yes		No RELRO		No Canary		NX disabled		Symbols		Networking
30	:	libuser_profile	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
30	:	libnetsnmp.so.1	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		Networking
29	:	zyshd	:	common linux file: no		No RELRO		No Canary		NX disabled		No Symbols		Networking
29	:	wtp_zyshd	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		Networking
29	:	uam-query	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking

[+] SYSTEM - top 10 results:

19	:	libmyzyxel_serv	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
12	:	libnetsnmpmibs.	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
9	:	lib2FA.so	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
5	:	winbindd	:	common linux file: no		RELRO		No Canary		NX disabled		Symbols		Networking
5	:	rlm_zy_rid.so	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
5	:	net	:	common linux file: yes		No RELRO		No Canary		NX disabled		Symbols		Networking
3	:	rlm_check_net.s	:	common linux file: no		No RELRO		No Canary		NX disabled		Symbols		No Networking
3	:	ntlm_auth	:	common linux file: yes		RELRO		No Canary		NX disabled		Symbols		Networking
3	:	nmbd	:	common linux file: yes		RELRO		No Canary		NX disabled		Symbols		Networking
3	:	libmttd.so	:	common linux file: no		No RELRO		No Canary		NX disabled		No Symbols		No Networking

[+] Found 43 setup files:

```
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/bin/write_enable_debug (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/libexec/dbus-daemon-launch-helper (-rwsr-x root daemon)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/fbwifi/auth/fbwifi_auth.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/bin/applyservice.suid (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/bin/ping (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/bin/zysudo.suid (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/webauth_error.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/bin/write_daas (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/dynamic_script.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/bin/get_property (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/lib/pppd/2.4.2/pppol2tp.so (-r-sr-x--- root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/traceroute (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/custom_webpage.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/agree.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/zylog_mailman (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/bin/ftp (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/fbwifi/continue/fbwifi_continue.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/tracepath6 (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/weblogin.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/redirect.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/sbin/conntrack (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/webauth_relogin.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/ping6 (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/tracepath (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/fbwifi/forward/fbwifi_forward.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/traceroute6 (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/lib/pppd/2.4.2/rp-pppoe.so (-r-sr-x--- root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/check_exp_pwd.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/myzyxel_registration.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/securpt.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/lib/pppd/2.4.2/openl2tp.so (-r-sr-x--- root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/tcpdump (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/check_need_wizard.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/bin/crontab (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/fetch_ap_info.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/sbin/matchfp (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/bin/applypwd.suid (-rwsr-xr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/2FA-access.cgi (-rwsr-sr-x root root)
/log/firmware/firmware_binwalk_emba/_firmware.extracted/squashfs-root/usr/local/zyxel-gui/htdocs/fbwifi_error.cgi (-rwsr-sr-x root root)
```

THE FUTURE

==> Collect CVE and exploit details.

[+] WARNING: Vulnerability CVE-2021-22600 is a known exploited vulnerability.
[+] WARNING: Vulnerability CVE-2016-5195 is a known exploited vulnerability.
[+] WARNING: Vulnerability CVE-2014-3153 is a known exploited vulnerability.
[*] Vulnerability details for kernel / version 3.10.87 / source STAT:

kernel	:	3.10.87	:	CVE-2022-2380	:	No exploit available
kernel	:	3.10.87	:	CVE-2021-4135	:	No exploit available
kernel	:	3.10.87	:	CVE-2019-15505	:	No exploit available
kernel	:	3.10.87	:	CVE-2019-15504	:	No exploit available
kernel	:	3.10.87	:	CVE-2019-15292	:	No exploit available
kernel	:	3.10.87	:	CVE-2019-14901	:	No exploit available
kernel	:	3.10.87	:	CVE-2018-5703	:	No exploit available
kernel	:	3.10.87	:	CVE-2018-20961	:	No exploit available
kernel	:	3.10.87	:	CVE-2018-12714	:	No exploit available
kernel	:	3.10.87	:	CVE-2017-7895	:	Exploit (Github: thdusdl1219_CVE-Study (G))
kernel	:	3.10.87	:	CVE-2017-13715	:	No exploit available
kernel	:	3.10.87	:	CVE-2016-9555	:	Exploit (Github: thdusdl1219_CVE-Study (G))
kernel	:	3.10.87	:	CVE-2016-7117	:	Exploit (Github: R0B1NL1N_linux-kernel-exploita (G))

[tion](#) (G) [skbasava_Linux-Kernel-exploit](#) (G) [Technoashofficial kernel-exploitation-linux](#) (G) [thdusdl1219_CVE-Study](#) (G) [xairy_linux-kernel-exploita](#) (G))

THE FUTURE

Experimental WSL support #274

Merged

BenediktMKuehne merged 21 commits into [e-m-b-a:master](#) from [m-1-k-3:master](#) 11 days ago

Shadow file detection, mipsn32 in user mode emulation, fixes

Open

m-1-k-3 wants to merge 7 commits into [e-m-b-a:master](#) from [m-1-k-3:master](#)



Conversation 0



Commits 7



Checks 1



Files changed 9



m-1-k-3 commented 7 hours ago • edited

Member



- What kind of change does this PR introduce? (Bug fix, feature, docs update, ...)

feature (better shadow file detection)

feature (mipsn32 in user mode emulator)

fixes in s13, s14 and s115

Thanks to your support [jaylagorio](#)

THE FUTURE

- Make a Python script
 - The deobfuscation function is at `0x10009F00` and is called from what calls `7za` at `0x10002DE0`
- Run the decrypted firmware through EMBA
 - `compress.img` is your friend
- Track whether and when Zyxel makes a breaking change to this process

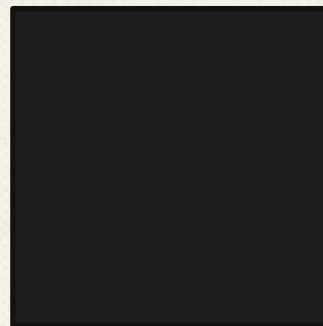
THE FUTURE



Plain-Text



Transition



Encrypted



THE FUTURE



Dave Aitel
@daveaitel

...

Like, to summarize: If your firmware images are encrypted, it generally just means you don't have faith in your security.

8:41 AM · 4/23/22 · [Twitter Web App](#)

3 Retweets **3** Quote Tweets **35** Likes



stacksmashing  @ghidrani... · 4/23/22 ...
Replying to [@daveaitel](#)

It's also in most cases just a nuisance, not really something that stops an attacker 😊

(Though having a slide where you can make fun of bad fw encryption is always good for a laugh)



11



THE FUTURE

Happy Bug Hunting!

AGENDA

- Introduction
- How it Started
- The Firmware
- The Hardware
- The Software
- How it's Going
- Future Work
- Questions

• ACKNOWLEDGEMENTS •

- My friends and family
- DEF CON CFP Review Team
- Niels Teusink (@NielsTeusink)
- Michael Messner for EMBA
- Author of Every Other Tool Mentioned
- The Ghidra Project (ghidra-sre.org)
- Everyone who previewed my talk

THANKS!

Questions?

Twitter: @jaylagorio

Github: @jaylagorio

Email: jay@lagor.io

